

資訊安全概論 · 第 06 章

系統安全 技術與規範

作業系統防護 · 存取控制 · 信任評估準則

“從架構到標準：建立可信賴的運算環境。”



本章地圖

01 系統安全三層面總覽

管理、技術與實體三道防線並重。

02 電腦與作業系統架構

四層運算架構與核心管理功能。

03 惡意程式常見威脅

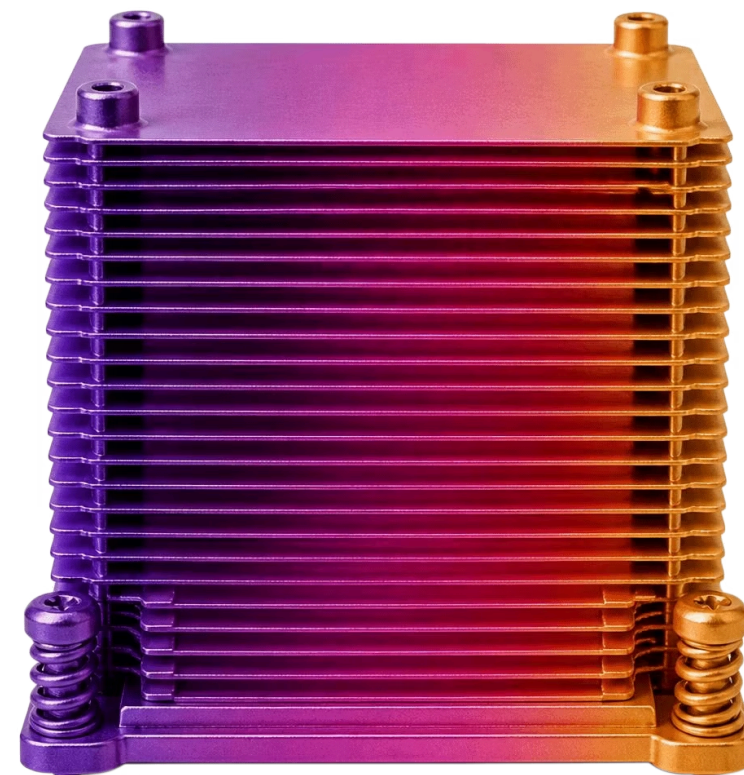
六種惡意程式型態與勒索軟體手腕。

04 存取控制三種機制

主體、客體權限矩陣與 RBAC 實作。

05 可信賴電腦系統評估

TCSEC 橘皮書、CC 共通準則與 TPM 晶片。



系統安全的三個層面

三道維度協同防禦，缺一不可



管理層面

制度與政策

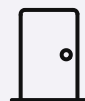
制定安全政策、作業標準、規範手冊與定期稽核程序，落實於日常管理與教育訓練。



技術層面

防護與控制

建構身分認證、存取控制、檔案加密、入侵偵測與系統防毒等核心技術工具。



實體層面

環境與設備

管制機房門禁、保護實體主機、規劃不斷電備援系統與防災溫濕度監控環境。

電腦系統的四層架構

由上而下遞降的軟硬體運算階層

01

應用軟體層

使用者直接操作的程式與工具。

02

作業系統層

管理軟硬體資源調度的核心系統。

03

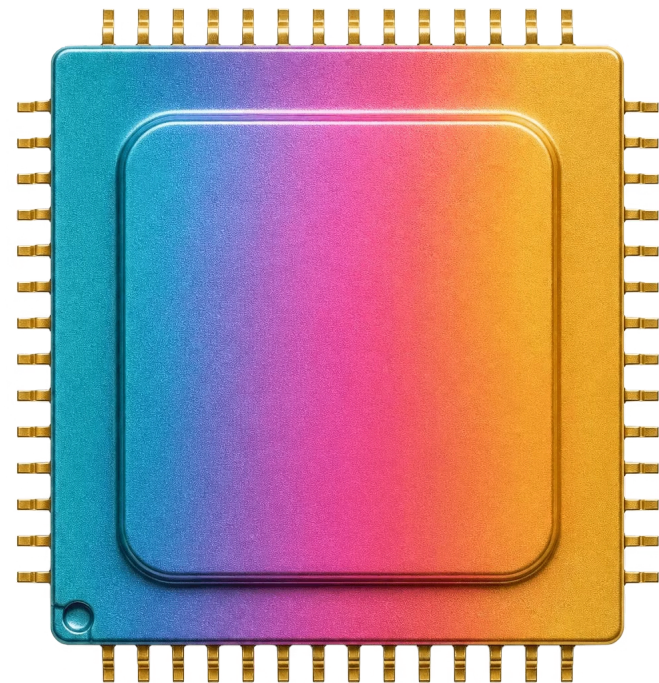
驅動程式層

轉譯溝通指令，連接硬體與系統。

04

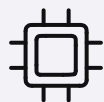
硬體層

CPU、記憶體與實體周邊設備。



作業系統的核心功能

資源分配與安全隔離的四大支柱



行程管理

有效排程各程式與行程，公平且安全地輪流分配有限的 CPU 運算資源，防止資源獨占。



記憶體管理

動態將待執行程式載入主記憶體，並在結束後回收空間，同時實施記憶體區段隔離保護。



檔案管理

以階層式目錄樹狀結構組織、儲存與快速索引檔案，並負責維護檔案讀寫權限管制。



裝置管理

統籌協調外接周邊、儲存裝置與系統 I/O 中斷，提供統一且抽象化的安全操作介面。

常見作業系統分類

因應不同硬體規模與運算情境的平台設計

個人運算環境

桌上型 OS

代表系統：Windows、macOS、Linux

重視人機圖形介面互動、多工作業支援以及多元周邊軟硬體的相容性。

可攜式智慧裝置

行動裝置 OS

代表系統：Android、iOS

專注於觸控人機互動、低功耗電源管理、感測器整合與應用程式沙盒隔離機制。

關鍵基礎設施

伺服器 / 嵌入式

代表系統：Linux Server、RTOS

因應大型雲端主機與專用工業、物聯網設備，強調高可用性、極致穩定與即時運算。



01

惡意程式 的威脅

隱蔽破壞、橫向擴散與勒索侵害的常見型態。

六種常見惡意程式

解析威脅行為特徵與傳播感染途徑



電腦病毒

附著於正常可執行檔案，藉由宿主執行觸發並自我複製擴散。



電腦蠕蟲

利用網路漏洞自主傳播與感染，不需依附任何特定宿主檔案。



木馬程式

偽裝成無害的正常軟體，誘騙使用者安裝後暗中執行惡意行為。



後門程式

繞過作業系統常規認證防線，替攻擊者保留長期的秘密遠端通道。



間諜／廣告軟體

未經許可蒐集使用者敏感隱私資料，或頻繁彈出未授權廣告干擾。



釣魚網頁

偽造銀行或知名服務登入介面，誘騙使用者自行輸入帳號密碼。

勒索軟體如何得手

01

社交工程誘導點擊

透過社交工程偽裝成抽獎信、中獎通知或帳單，誘騙使用者點擊

02

執行後鎖住檔案與文件

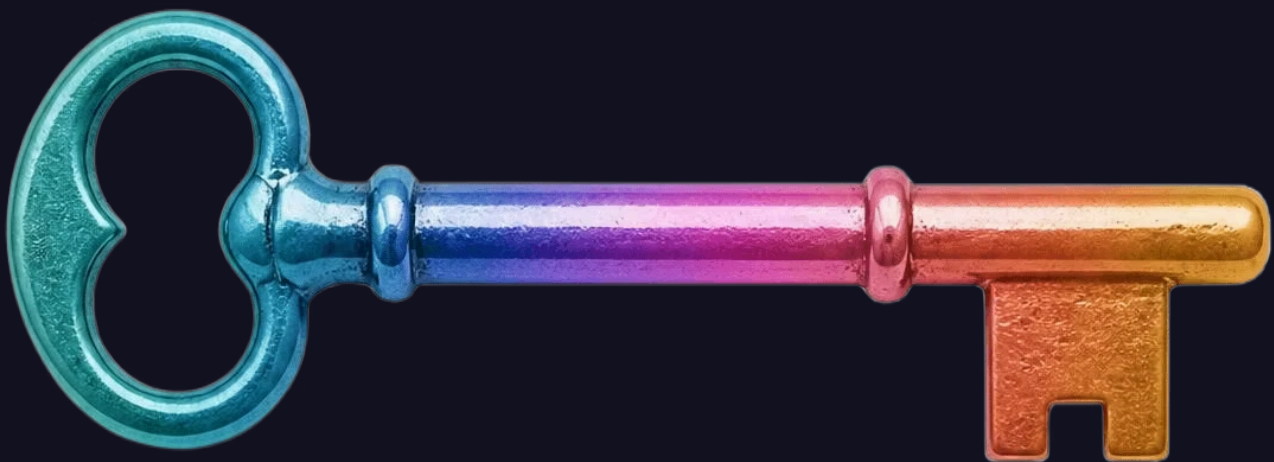
執行後鎖住電腦中的檔案與文件

03

跳出勒索警告視窗

並跳出勒索警告視窗要求付款才能解鎖。





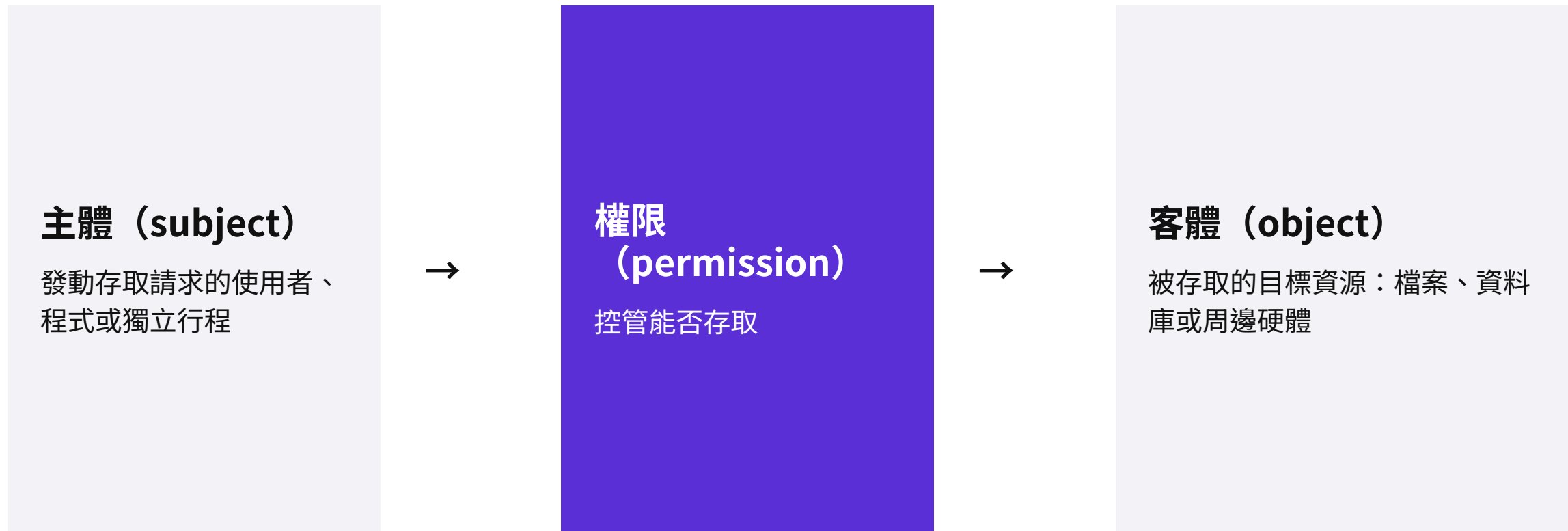
02

存取控制 機制

作業系統落實資源保護與權限管制的
防護網。

存取控制的核心概念

作業系統控管資源存取的三大要素架構



存取控制是作業系統管理系統資源的機制，依**主體 (subject)** 的**權限 (permission)**，控管其能否存取特定**客體 (object)** 資源。

三種存取控制方法比較

主流系統實作架構與適用場景比對

機制類型	運作原理與清單維護位置	特點與典型應用場景
ACL 存取控制清單	客體維護清單：每個客體（如檔案）記錄哪些主體擁有其讀寫權限。	直觀且便於查詢特定檔案的授權對象；常見於作業系統檔案系統與資料庫權限表。
主體功能表 Capability List	主體維護清單：每個主體（如使用者或行程）攜帶自身可存取的客體與權限憑證。	便於主體管理自身權杖並進行權限傳遞；常見於分散式運算系統與權限票券機制。
RBAC 角色基存取控制	以角色為中介：先定義系統業務角色並指派權限，人員透過指派角色取得存取權。	大幅簡化大量人員異動與權限指派管理；已成為現代企業大型應用系統之核心標準。



03

可信賴 電腦系統

國際安全評估標準與硬體信任根的演進。

TCSEC 橘皮書：四類七級

美國國防部可信賴電腦系統評估準則（安全等級由低至高）

D

最低保護

無任何安全保護機制，系統經評估未達基本門檻。

C1 / C2

自主存取控制

DAC：依身分自主授權。C2 提供稽核日誌與身分鑑別，為商用系統常見標準。

B1–B3

強制存取控制

MAC：依安全標籤強制管制。由 B1（標記）至 B3（網域隔離），安全層級逐級遞增。

A1

驗證式保護

最高等級：安全核心設計經過嚴謹的形式化數學模型驗證，具最高信賴度。

CC 共通準則：整合四大標準

COMMON CRITERIA (ISO/IEC 15408) 國際安全評估共通架構

加拿大標準
CTCPEC

可信賴電腦產品評估準則

歐洲標準
ITSEC

資訊技術安全評估準則

美國國防部
TCSEC

橘皮書電腦系統評估準則

美國聯邦
FC

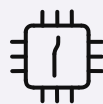
聯邦資訊處理安全準則

融合統一為全球通用標準 (ISO/IEC 15408)

將各國互不相容之準則融合成單一評估架構，明確劃分安全功能要求（SFR）與安全保證要求（SAR，分為 EAL1 至 EAL7 七個保證等級），實現跨國認證互通。

可信賴平台模組 (TPM)

硬體信任根：安全開機與金鑰防護的核心晶片



硬體規格標準

由可信賴運算組織（TCG）制定，直接獨立焊接於電腦主機板上的防竄改安全晶片。



安全金鑰管理

晶片內部封裝專屬運算單元，在隔離硬體中生成、儲存與保護加解密根金鑰。



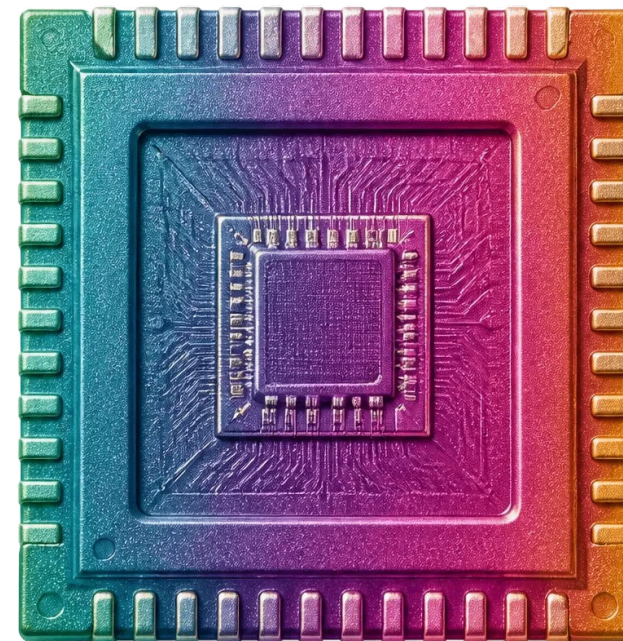
數位簽章與鑑別

提供硬體級非對稱密碼運算，具備平台完整性度量與高信賴度的身分認證功能。



可信賴度量開機

作為系統信任鏈之根基（Root of Trust），從開機韌體起逐層驗證系統未遭竄改。



本章重點回顧

第 06 章 核心觀念統整



三維防護體系

系統安全必須管理政策、技術機制與實體防護三者緊密結合，不可偏廢任一環節。



威脅多樣性與人性漏洞

惡意程式型態多元且分工細緻；社交工程與勒索軟體常鎖定人性的疏忽造成系統重創。



存取控制與權限管理

ACL 便於客體管理，主體功能表利於票券傳遞，而 RBAC 則是企業大規模權限配置之首選。



評估準則與硬體信任根

TCSEC 奠定分級基礎，CC 成為跨國標準，搭配硬體 TPM 晶片落實端對端的安全信任鏈。